

FICHE DE NOTES ISO 27001 :2022

Clauses 4, 5 et 6

Auteur : Mechac Banzolako Ndikuna

Date : mercredi, le 20/05/2026

CLAUSE 4 CONTEXTE DE L'ORGANISATION

Sous clause	Ce que ça signifie	Exemple CIUSSS
4.1 Contexte interne & externe	L'organisation évolue dans un environnement strictement réglementés	Lois québécoises, cultures interne, budget, fournisseurs, employés, lois 25, MSSS
4.2 Parties intéressées	Identifier qui est impacté par la sécurité de l'information	Les patients, personnel médical, le gouvernement, RAMQ
4.3 Périmètre du SMSI	Quels sont les processus ou les systèmes couverts par le SMSI	Dossiers patients électroniques (DSE), réseau intranet du CIUSSS, applications cliniques
4.4 Le SMSI lui-même	Établir, implémenter et améliorer le système de management	Responsable de la sécurité de l'information (RSSI) et le comité de sécurité

CLAUSE 5 LEADERSHIP ET ENGAGEMENT DE LA DIRECTION

Sous-clause	Obligation de la direction	Livrable concret
5.1 Leadership et engagement	Doit attribuer des rôles et responsabilités, pourvoir d'un budget	Mémo de la DG approuvant le SMSI + budget alloué
5.2 Politique de sécurité	Rédiger, approuver et communiquer une politique de sécurité de l'information à tous les employés	Politique signée par le DG diffusée à tous les employés
5.3 Rôles et responsabilités	Définir clairement qui est responsable de quoi dans le SMSI	Organigramme sécurité : RSSI, Comité sécurité, propriétaires d'actifs

CLAUSE 6 PLANIFICATION

Sous clause	Ce qu'on doit faire	Méthode / Outil
6.1.1 Actions pour risques et opportunités	Identifier les risques qui peuvent affecter les objectifs du SMSI	Registre des risques ISO 27005 / EBIOS RM
6.1.2 Évaluation des risques	Évaluer chaque risque selon sa probabilité (1-5) et son impact (1-5)	Matrice 5x5 (probabilité x impact)
6.1.3 Traitement des risques	On doit décider si le risque doit être atténuer, transférer, éviter ou accepter	Plan de traitement des risques
6.2 Objectifs de sécurité	100% des logiciels mis à jour d'ici 3 mois responsable équipe TI	Tableau d'objectifs avec échéances et responsables

RÉFLEXION PERSONNELLE

QUOI ? Aujourd'hui j'ai étudié les clauses 4, 5 et 6 d'ISO 27001 :2022 et créé une fiche de notes appliquée au contexte d'un hôpital CIUSSS"

APPRIS ? La plus importante que j'ai apprise sur ISO 27001 aujourd'hui est que les sociétés ne sont pas obligées de mettre en pratique l'iso27001 mais en le mettant sa leur procure des avantages comme : le respect des obligations légales, un avantage concurrentiel, réduction des couts et une meilleure organisation

DIFFICILE ? le plus difficile à comprendre est les jargons du métier à le placer au bon endroit et il faut connaitre réellement le périmètre avant de commencer